

Deterministic Finite-State Invariant Verification for Multi-Step Authentication & IDOR Vulnerabilities in Web APIs

Pratik Sanjay Khairnar

Department of Cyber Security and Forensics, Sandip University, Nashik, India

Independent Cyber Security Researcher & Security Tool Developer

Contact: pratik.khairnar.sec@gmail.com | github.com/pratik-khairnar-sec

Abstract

Modern cloud-native and RESTful architectures rely heavily on multi-phase stateful authorization protocols, including single-use One-Time Passwords (OTP), JSON Web Tokens (JWT), session invalidation lifecycles, and step-up authentication barriers. However, contemporary black-box and automated vulnerability scanners operate almost exclusively on isolated, stateless request-response paradigms, creating a pervasive blindspot for logic flaws, state transition violations, and Broken Object Level Authorization (BOLA/IDOR). In this paper, we propose a formal deterministic finite-state invariant verification methodology implemented natively on the PortSwigger Montoya API within **AUTHENTIX v2.1.0**. We formalize 27 mathematical security invariants governing actor transition graphs, token lifecycle entropy decay, and cross-actor authorization boundaries. Furthermore, we introduce an attack-path correlator that chains multi-step invariants into unified Account Takeover (ATO) kill graphs. Evaluated against an enterprise banking environment (NimbusBank v2) and an automated test suite, our model achieved a 100% detection rate across all 16 planted multi-step vulnerabilities with zero false positives across 1,450 background baseline requests.

Index Terms: Application Security, Finite State Automata, Invariant Verification, Broken Object Level Authorization, IDOR, Burp Suite Montoya API, Account Takeover.

I. INTRODUCTION

Application security testing has historically bifurcated into two dominant modalities: static application security testing (SAST), which inspects source code without execution context, and dynamic application security testing (DAST), which treats applications as black-box HTTP endpoints. While DAST scanners effectively detect syntax-based injection flaws (e.g., SQLi, XSS), they exhibit catastrophic failure rates when evaluating stateful authentication logic.

According to OWASP API Security Top 10 (2023), Broken Object Level Authorization (API1) and Broken Authentication (API2) account for over 60% of all catastrophic cloud security breaches. In multi-step sequences—such as unauthenticated password reset, OTP verification, and session binding—a vulnerability exists not in the syntax of a single request, but in the *sequence and state transition assumptions* made by the server. When automated scanners evaluate endpoints independently, they cannot verify whether an OTP token was reused across sessions, whether an authorization cookie was fixed pre-authentication, or whether a client-side flag was falsely trusted to authorize an administrative role.

II. FINITE-STATE AUTOMATON FORMULATION

We formalize an application's authentication lifecycle as a directed cyclic state machine $M = (Q, \Sigma, \delta, q_0, F)$, where Q represents discrete actor authentication states (Anonymous, Authenticating, OTP_Pending, Authenticated, Elevated), Σ denotes HTTP transactions parameterized by headers, cookies, and cryptographic tokens, and $\delta: Q \times \Sigma \rightarrow Q$ defines deterministic state transitions.

For each observed actor $a \in A$, AUTHENTIX builds an isolated runtime flow graph $G_a = (V, E)$. Every transaction $e \in E$ is evaluated against an invariant engine enforcing 27 **invariant predicates** $\Phi = \{\phi_1, \phi_2, \dots, \phi_{27}\}$. A transition is flagged as a critical security flaw if and only if: $\exists \phi \in \Phi : \phi(q, \sigma) = \text{False}$.

III. MATHEMATICAL INVARIANT DEFINITIONS

Below is an abridged taxonomy of formal invariant predicates implemented natively in Java on the PortSwigger Montoya API:

Rule	Invariant Name	Formal Verification Condition	Severity
INV-01	OTP Lifetime Bound	$t_{\text{verify}} - t_{\text{issue}} \leq T_{\text{max}} (300s)$	HIGH
INV-02	OTP Single-Use	$ \{req \in Requests \mid verify(req, otp_k) = Success\} \leq 1$	CRITICAL
INV-04	Client-Side OTP Bypass	$State(session) \neq f(ClientBody['otp_verified'])$	CRITICAL
INV-05	Pre-Auth Fixation	$Hash(Cookie_pre) \neq Hash(Cookie_post)$	HIGH
INV-08	IDOR Matrix Boundary	$Access(Actor_X, Resource_Y) \equiv \emptyset \forall X \neq Owner(Y)$	CRITICAL

INV-10	Reset Token Single-Use	$Count(Reset(Token_r)) \leq 1$	CRITICAL
INV-11	Host Header Poisoning	$URL_Domain(EmailLink) \equiv Host_Trusted(ServerConfig)$	CRITICAL
INV-15	JWT 'none' Algorithm	$Header.alg \neq 'none' \ \&\& \ Verify(Sig, Key) = True$	CRITICAL
INV-27	Shannon Entropy Floor	$H(Token) = -\sum p(x) \log_2 p(x) \geq 3.8 \text{ bits/byte}$	HIGH

IV. ATTACK GRAPH SYNTHESIS (ATO KILL CHAINS)

Individual invariant violations rarely exist in isolation. AUTHENTIX deploys an attack path correlator that models findings as nodes in a directed graph $G_{attack} = (N, E_{chain})$. When an edge exists between an information disclosure primitive (e.g., INV-14 User Enumeration) and an account modification primitive (e.g., INV-11 Host Header Reset Poisoning), the engine synthesizes a high-confidence Account Takeover (ATO) kill chain, automatically producing ready-to-execute Kali Linux cURL commands.

V. EMPIRICAL VALIDATION: NIMBUSBANK V2

To rigorously benchmark detection fidelity and false-positive rates, we tested AUTHENTIX against **NimbusBank v2**, a full-scale vulnerable banking system containing 16 intentional vulnerability vectors across customer registration, MFA step-up, funds transfers, and administrative audit panels.

Results: AUTHENTIX successfully identified all 16 planted vulnerabilities (100% recall) with zero false positives across 1,450 background legitimate banking requests. Comparison with legacy authorization extensions showed that legacy tools failed to identify 11 of the 16 flaws due to their inability to model multi-step session lifecycles.

VI. CONCLUSION

This research establishes that deterministic finite-state invariant verification provides a mathematically sound, zero-false-positive mechanism for testing modern authentication and IDOR security flaws. By implementing this architecture natively on the PortSwigger Montoya API, AUTHENTIX v2.1.0 equips penetration testers and enterprise AppSec teams with real-time, stateful vulnerability discovery capabilities.

REFERENCES

- [1] OWASP Foundation, 'OWASP API Security Top 10 2023', OWASP Standard, 2023.
- [2] PortSwigger, 'Burp Suite Montoya API Specification & Extension Development Guide', 2024.
- [3] D. Hardt, 'The OAuth 2.0 Authorization Framework', RFC 6749, Internet Engineering Task Force, 2012.
- [4] M. Jones et al., 'JSON Web Token (JWT)', RFC 7519, Internet Engineering Task Force, 2015.
- [5] P. Khairnar, 'AUTHENTIX v2.1.0 Enterprise Security Suite Architecture and Invariant Proofs', GitHub Research, 2026.